

Scenario Gym — Training Notes

August 15, 2026 · AWS IAM / CloudTrail Identity Compromise

Scenario

A CloudTrail alert fired for **CreateAccessKey** against IAM user **svc-prod-backup**. The key was created through an assumed-role session belonging to **admin-operations**. The legitimate administrator denied creating it. The exercise expanded into tracing the identity chain, determining effective permissions, scoping attacker activity, identifying persistence, and containing the full attack path.

Core Mental Models

- **Access key $\neq$ permissions.** An access key is a credential used to authenticate as an IAM user. The principal's effective authorization determines what the credential can do.
- **Investigate upstream and downstream.** Downstream asks what the attacker did after obtaining access. Upstream asks how the attacker obtained the identity/session that enabled the malicious action.
- **CloudTrail shows activity, not the complete current authorization state.** Use CloudTrail to reconstruct API activity; inspect IAM policies/configuration and other controls to understand effective permissions.
- **IOC containment $\neq$ attack-path containment.** Revoking one malicious key may leave the original compromised identity, role session, or newly established persistence intact.

AWS Concepts to Reinforce

Concept	Working definition / lesson
IAM user	Long-lived AWS identity that can have permissions and credentials such as access keys.
IAM group	A way to assign permissions to collections of IAM users. A group is not an assumed role.
IAM role	An identity that is assumed to obtain a temporary session; commonly used for delegated or workload access.
AWS STS / AssumeRole	Mechanism used to obtain temporary credentials for a role session. Investigators should trace who or what assumed the role.
Managed / inline policy	Permission policies can be attached through multiple paths. Inspect all relevant sources rather than one policy in isolation.
Resource-based policy	A policy attached to a resource, such as an S3 bucket policy; distinct from an IAM identity policy.
"Action": "s3:*"	Potentially permits all S3 actions covered by the wildcard, subject to the rest of AWS authorization evaluation.
"Resource": "*"	The statement is not restricted to one specific resource; interpret it together with Action, Effect, Conditions, and other parts of the policy.

Identity Chain From the Exercise

jdoe → **AssumeRole** → **admin-operations temporary session** → **CreateAccessKey** → **svc-prod-backup** → **malicious access key** → **attacker API activity**

The key lesson was to avoid stopping at the newest malicious artifact. If the attacker could operate through **admin-operations**, the investigation must determine what original principal or mechanism produced that role session. In the exercise, CloudTrail's **AssumeRole** activity linked the suspicious role session back to **jdoe**.

Attacker Behaviors Discussed

Behavior	Examples / interpretation
Discovery	GetCallerIdentity, ListBuckets, examining bucket policy/encryption and other configuration.
Collection / possible exfiltration	GetObject and unusual/bulk object access. Reading data is more serious than simple enumeration.
Persistence	CreateUser, CreateAccessKey, creating/modifying roles or trust relationships, adding alternate authentication
Privilege escalation	Attaching powerful policies or modifying permissions to gain stronger authority.
Defense evasion	StopLogging, DeleteTrail, or other audit/logging changes. These are not the same thing as persistence.

Diagnostic Notes

Strengths: good detection instincts; natural pivots on suspicious IP/credential usage; increasingly concrete CloudTrail hunting; recognized S3 enumeration/object access, account/key creation, log tampering, and attacker sequencing.

Primary growth area: AWS identity architecture and authorization depth. Continue reinforcing IAM user vs group vs role, STS/temporary sessions, policy types, trust relationships, effective permissions, and how to trace identity compromise through CloudTrail.

Important: These notes are diagnostic data, not a requirement that the next Scenario Gym lesson be AWS. The curriculum remains adaptive and may move to another domain while revisiting these concepts later in new contexts.

Quick Defender Questions

- Who performed the action — IAM user, role, or temporary role session?
- What authenticated that principal, and can I trace the identity chain backward?
- What effective permissions did the principal have?
- Has the suspicious credential/session been used, and what API actions followed?
- What resources were read, modified, created, or deleted?
- Did the attacker establish another identity, credential, permission, or trust path?
- Have I contained only the IOC, or have I broken the full attack path?